

01/03) 0, 1. Introduction and Web (1)

1. Web

Background: Web

기본지식: Flask, Node js, Spring 언어에 대한 이해

웹이란

인터넷 기반 서비스 중 HTTP를 이용한 정보 공유 서비스
정보 제공 주체는 **웹 서버**, 정보 이용자는 **웹 클라이언트**

| HTTP: 통신 프로토콜

웹 서비스

이전과 달리 이용자의 요청을 받아들여 수행하고 필요한 정보를 제시하는 쪽으로 변화함
이때 요청받는 부분은 **프론트엔드**, 처리하는 부분은 **백엔드**

웹 리소스

웹에 갖춰진 정보 자산

모든 웹 리소스는 고유의 URL로 식별됨

- HTML : 웹 문서의 골격
- CSS: 디자인 역할
- JavaScript(JS): 동작, 반응 역할

웹 서버-클라이언트 통신 과정

1. 클라이언트: 웹 서버 접속
2. 클라이언트: 브라우저가 요청 해석, HTTP 형식으로 서버에 리소스 전달
3. 서버: 리소스 해석

4. 서버: 적절한 처리
5. 서버: HTTP 형식으로 리소스 응답
6. 클라이언트: 웹 리소스 시각화하여 클라이언트에게 제시

관련: [[1.1 HTTP]] [[1.2 Web Browser]]

1.1 HTTP

프로토콜

규격화된 상호작용에 적용되는 약속
ex) TCP/IP, HTTP, FTP

HTTP

[!NOTE] Hyper Text Transfer Protocol

서버와 클라이언트의 데이터 교환을 요청과 응답으로 정의한 프로토콜

클라이언트가 웹 서버의 TCP/80 또는 TCP/8080인 서비스 포트에 HTTP 요청을 전송하면 응답을 반환함

네트워크 포트

네트워크 포트: 네트워크에서 서버와 클라이언트가 정보를 교환하는 장소

서비스 포트: 네트워크 포트 중 특정 서비스가 점유하는 포트

데이터 교환 방식은 **전송계층**의 프로토콜을 따름.

ex. TCP 전송 서비스에 UDP 클라이언트 접근 시 데이터 교환 불가

윈도우나 리눅스, 맥은 **0번부터 65535번**까지의 네트워크 포트 사용

0~1023번 포트는 Well-known port 또는 Privileged port

= 각 번호에 유명한 서비스가 등록되어 있음

HTTP 메시지 구조

헤드

첫 줄인 <u>시작 줄</u>과 나머지 <u>헤더</u>로 구분

시작 줄: 요청과 응답 관련 정보

헤더: 필드와 값으로 구성, HTTP 메시지나 바디의 속성 표시

바디

헤드의 끝을 나타내는 CRLF 뒤의 모든 줄.

전송하려는 데이터 표시

(즉 헤드와 바디는 빈 줄로 구분)

[!NOTE] CRLF란?

Carriage Return과 Line Feed의 조합으로, 개행을 위한 문자열을 의미

HTTP 요청

```
GET /index.html HTTP/1.1
Host: dreamhack.io
Connection: keep-alive
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_6)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.88
Safari/537.36
```

시작 줄

- 메소드(Method), 요청 URL, HTTP 버전
- 띄어쓰기로 구분
- 메소드: 서버에 요청하는 동작
 - GET: 리소스를 가져와라
 - POST: 리소스로 데이터를 보내라

참고: 표준문서

HTTP 응답

```
HTTP/1.1 200 OK
Server: Apache/2.4.29 (Ubuntu)
```

```
Content-Length: 61
Connection: Keep-Alive
Content-Type: text/html
<!doctype html>
<html>
<head>
</head>
<body>
</body>
</html>
```

시작 줄

- HTTP 버전, 상태 코드(Status code), 처리 사유(Reason Phrase)
- 상태 코드: 처리 결과에 대한 세 자리 숫자
- 첫 번째 자리에 따라 5개로 분류

상태코드	설명	대표 예시
1xx	요청 받고 처리 중	
2xx	요청이 처리 됨	- 200(OK): 성공
3xx	처리를 위해 추가 동작 필요	- 302(Found): 다른 URL로 갈 것
4xx	잘못된 요청으로 처리 실패	- 400(Bad Request): 요청이 문법에 맞지 않음 - 401(Unauthorized) : 클라이언트가 요청한 리소스에 대한 인증이 실패함 - 403(Forbidden): 클라이언트가 리소스에 요청할 권한 없음 - 404(Not Found): 리소스가 없음

- 참고: [표준 문서](#)

HTTPS

HTTP 메시지는 평문으로 전달되므로, 정보 유출 위험 가능성이 있음
따라서 TLS(Transport Layer Security) 프로토콜을 이용해 HTTP 메시지를 암호화
Wireshark[^1]와 같은 프로그램으로 패킷을 캡처하여도 읽을 수 없음
URL이 `http://` 로 시작되면 HTTP, `https://` 로 시작되면 HTTPS 프로토콜

[^1]: 네트워크 패킷의 캡처 및 분석을 위한 소프트웨어

1.2 Web Browser

웹 브라우저

인터넷 위에 구현된, 특정 프로토콜 기반의 통신 소프트웨어

브라우저의 동작 과정

1. URL 분석: 주소창에 입력된 주소 해석
2. DNS 요청: 해당 주소 탐색
3. HTTP를 통해 해당 주소에 요청
4. 해당 주소로부터 HTTP 응답 수신
5. 리소스 다운로드, 웹 렌더링 (HTML, CSS, JS)

URL(Uniform Resource Locator)

웹에 있는 리소스의 위치를 표현하는 문자열

URL 구조

![[Pasted image 20240102221301.png]]

- Scheme: 통신 프로토콜
- Host: Authority의 일부로, 접속할 서버 주소에 대한 정보
- Port: Authority의 일부로, 접속한 서버 포트에 대한 정보
- Path: 접근할 웹 서버의 리소스 경로
- Query: 웹 서버에 전달하는 파라미터, '?' 뒤에 위치
- Fragment: 메인 리소스의 서브 리소스 접근 시 필요한 식별 정보, '#' 뒤에 위치

Domain Name

Host는 **Domain Name**과 **IP Address**을 가질 수 있음

IP Address: 통신 시 장치 식별을 위해 사용되는 주소

도메인 이름: 외우기 어려운 IP 대신 사용하는 이름

도메인 이름을 DNS에 질의, DNS가 응답한 IP Address와 통신
도메인 이름에 대한 정보는 `nslookup` 명령어로 확인 가능

```
PS C:\\Users\\PR0> nslookup naver.com
서버:      kns.kornet.net
Address:   168.126.63.1

권한 없는 응답:
이름:      naver.com
Addresses: 223.130.200.104
           223.130.195.200
           223.130.195.95
           223.130.200.107
```

다음: [[1.2.1 Browser DevTools]]

1.2.1 Browser DevTools

개발자 도구(Devtools)

- HTML과 CSS 코드를 브라우저에서 수정하고 바로 결과를 확인하는 등 웹 개발을 편하게 만들어주는 도구
- 반면 웹 취약점 공격자에게도 유용하게 사용 가능
- F12를 눌렀을 때 나오는 게 바로 개발자 도구

![[Pasted image 20240102224607.png]]

- 왼쪽 상단: 요소 검사(Inspect) 및 디바이스 툴바(Device Toolbar)
 - **요소 검사:** 커서 올리면 관련 코드 하이라이팅
 - **디바이스 툴바:** 다양한 디바이스 별 비율로 확인 가능
- 패널
 - Elements: 페이지를 구성하는 HTML 검사

- Console: 자바 스크립트 실행 및 결과 확인 가능
- Sources: HTML, CSS, JS 등 리소스 확인 및 디버깅
- Network: 서버와 오가는 데이터 확인
- Application: 쿠키 포함 웹 app과 관련된 데이터 확인

Elements

HTML 수정

코드 선택 후 F2 누르면 수정 가능

Console

JS 코드에서 발생한 메세지 출력, 이용자가 입력한 JS 코드 실행

웹 개발 시 `console` 오브젝트에 개발자 도구 콘솔에 접근가능한 함수가 정의되어 있음
(단축키: Ctrl + Shift + J)

1. `alert("hello");` 팝업 박스로 출력하기
![[Pasted image 20240102225934.png]]
2. `var value = prompt('input');` 팝업 박스로 입력 받기
![[Pasted image 20240102230101.png]]
3. `var true_false = confirm('yes or no ?');` Boolean 값 입력
4. `documentn.body.innerHTML = '<h1>Refresh!</h1>';` document.body를 변경
5. `document.body.innerHTML += '<h1>HI!</h1>';` document.body에 새로운 html 코드 추가

Sources

현재 페이지를 구성하는 웹 리소스 확인 가능

맨 오른쪽: 디버깅 정보

[!NOTE] 디버깅 정보 탭

- Watch: 코드 실행 과정에서 해당 식의 값 변화 확인
- Call Stack: 함수들의 호출 순서를 스택 형태로 보여줌
- Scope: 정의된 모든 변수들의 값 확인
- Breakpoints: 브레이크포인트 확인, 각각 활성화 선택 가능

디버깅 실습

Sources에서 해당 코드를 찾은 후 라인 번호에 우클릭 -> 중단점 추가
옆의 scope에서 변수 확인 가능

![[Pasted image 20240103002425.png]]

Network

![[Pasted image 20240103002639.png]]

- 옵션
 - Preserve log: 새로운 페이지 이동 시 로그 삭제하지 않음
 - Disable cache: 이미 캐시된 리소스도 서버에 요청
- Copy as fetch로 요청을 복사하고 Console 패널에 붙여 실행하면 동일한 요청 재전송 가능

Application

쿠키, 캐시, 이미지, 폰트, 스타일시트 등 웹 어플리케이션 관련 리소스 조회 가능
Cookies: 저장된 쿠키 정보 확인 및 수정 가능

Console Drawer

단축키 Esc로 새 콘솔창 열 수 있음

시크릿 모드

시크릿 모드 시 저장되지 않는 항목
단축키: Ctrl + Shift + N

- 방문 기록
- 쿠키 및 사이트 데이터
- 양식에 입력한 정보
- 웹사이트에 부여된 권한

picoCTF - Who are you?

Key: Burp Suite를 이용해 HTTP 요청과 응답을 요구에 맞게 변조하는 것

Burp Suite에서 응답이 뜨지 않아서 구글링 해봤는데 아마 문법의 문제인 듯
마지막에 개행을 해주었을 때 정상적으로 나왔음 [참고](#)

```
GET / HTTP/1.1
Host: mercury.picoctf.net:36622
Upgrade-Insecure-Requests: 1
User-Agent: PicoBrowser
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Connection: close
Referer: mercury.picoctf.net:36622
Date: Wed, 21 Oct 2018 07:28:00 GMT
DNT: 1
Content-Length: 0
Accept-Language: sv-SWE
X-Forwarded-For: 92.34.186.83
```

관련 정보: [[HTTP 헤더]]

참고자료: [MDN](#)

1. User-Agent: 사용자 에이전트의 애플리케이션 타입, 운영 체제, 소프트웨어 벤더 또는 소프트웨어 버전을 식별할 수 있는 특성 문자열 포함

▼ General form

```
Mozilla/5.0 (platform; rv:geckoversion) Gecko/geckotrail
Firefox/firefoxversion
```

Mozilla/5.0 : 엄청 오래된 브라우저를 사용하는 웹사이트에서도 호환이 되도록 구버전의 Mozilla와 호환이 된다는 의미

platform : 브라우저가 실행되고 있는 native platform(윈도우, 맥, 리눅스 등)

rv:geckoversion : 현재 릴리즈된 Gecko 버전

Gecko/geckotrail : 브라우저가 Gecko 기반임을 의미. 데스크탑에서 **geckotrail** 은 20100101의 고정된 문자열을 가짐

`Firefox/firfoxversion` : 현재 브라우저가 firefox이며, 버전 알려줌

2. Referer: 현재 페이지로 연결되는 링크가 있던 이전 웹 페이지의 주소

3. Date: 메시지가 발생한 날짜와 시간 포함

```
Date: <day-name>, <day> <month> <year> <hour>:<minute>:<second> GMT
```

<day-name> : 요일, Mon, Tue 등

<day>: 2자리의 일자 번호

<month>: 월, Jan, Feb 등

<year>: 4자리의 연도 번호

<hour>: 2자리의 시간 번호, 23 등

<minute>: 2자리의 분 번호

<second>: 2자리의 초 번호

GMT: 그리니치 표준시

4. X-Forwarded-For(XFF): 웹 서버에 접속하는 클라이언트의 원 IP 주소를 식별하는 헤더. 중간에 프록시나 로드 밸런서를 거치면 서버 접근 로그에 프록시나 로드 밸런서의 IP 주소만을 담고 있어서, 원 IP 주소를 보기 위해 사용됨

```
X-Forwarded-For: <client>, <proxy1>, <proxy2>
```

<client>: 클라이언트 IP 주소

<proxy1>, <proxy2>: 요청이 여러 프록시들을 거칠 때, 각 프록시의 IP 주소들이 열거됨. 가장 오른쪽 주소로 갈수록 나중에 거친 프록시의 IP 주소. 가장 왼쪽은 최초 클라이언트의 IP 주소

5. DNT(Do Not Track): 애플리케이션으로 하여금 사이트 내부, 혹은 타 사이트를 통해 개인 사용자를 추적하는 행위를 거부하도록 요청을 보내주는 것.

- DNT: 1 일 경우 추적당하지 않고 싶다는 의미

